Alexander Ticket

Note: This report has been sanitized for public sharing.

All internal IPs, hostnames, and Splunk URLs have been redacted or replaced with simulated values.

Report was originally prepared for Jira; internal console links are not publicly accessible. Query references shown for context

QRadar ID: ******

Description

Suricata and QRadar triggered a critical offense including **"Trojan Detected preceded by Web Exploit"** from **109.248.170.188** to `[internal web server]` over HTTP port 80. The incident involves a multi-stage exploitation campaign attributed to the **RedTail botnet** (User-Agent: libredtail-http).

The threat actor initially attempted obfuscated Path Traversal via the /cgi-bin/ directory to execute /bin/sh (HTTP 400). Following this, the attacker successfully executed a **PHP CGI Argument Injection attack** and **PEAR Command Injection** payloads targeting /index.php. Analysis confirms successful **Remote Code Execution (RCE)**, as evidenced by multiple **HTTP 200 (OK)** responses and a subsequent attempt to verify a dropped malicious PHP shell in the /tmp/ directory.

Victim:

`[internal web server] - redacted-domain.local`

Log 1: Initial Reconnaissance (Failed Path Traversal) Source Log #1

** 1 Encoded log:**

"/cgi-bin/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/bin/sh"

** 1 Decoded log:**

"/cgi-bin/../../../../../../../../../../bin/sh"

Log 2: Successful PHP-CGI Argument Injection Source Log #6

** 2 Encoded log:**

"/?%ADd+allow_url_include%3d1+%ADd+auto_prepend_file%3dphp://input"

** 2 Decoded log:**

"/?-d allow_url_include=1 -d auto_prepend_file=php://input"

Log 3: PEAR Command Injection (Payload Dropper) Source Log #11

** 3 Encoded log:**

"/index.php?lang=../../../../../../../../usr/local/lib/php/pearcmd&+config-create+/&/<?echo(md5(\"hi\"));?>+/tmp/index1.php"

** 3 Decoded log:**

"/index.php?lang=../../../../../../../../usr/local/lib/php/pearcmd & config-create / & /<?echo(md5("hi"));?> /tmp/index1.php"

Log 4: Verification of the Malicious Shell Source Log #10

** 4 Encoded log:**

"/index.php?lang=../../../../../../../../tmp/index1"

** 4 Decoded log:**

"/index.php?lang=../../../../../../../../tmp/index1"

ATTACKER INFO:

IP: `109.248.170.188` on port `51470 and 51500`

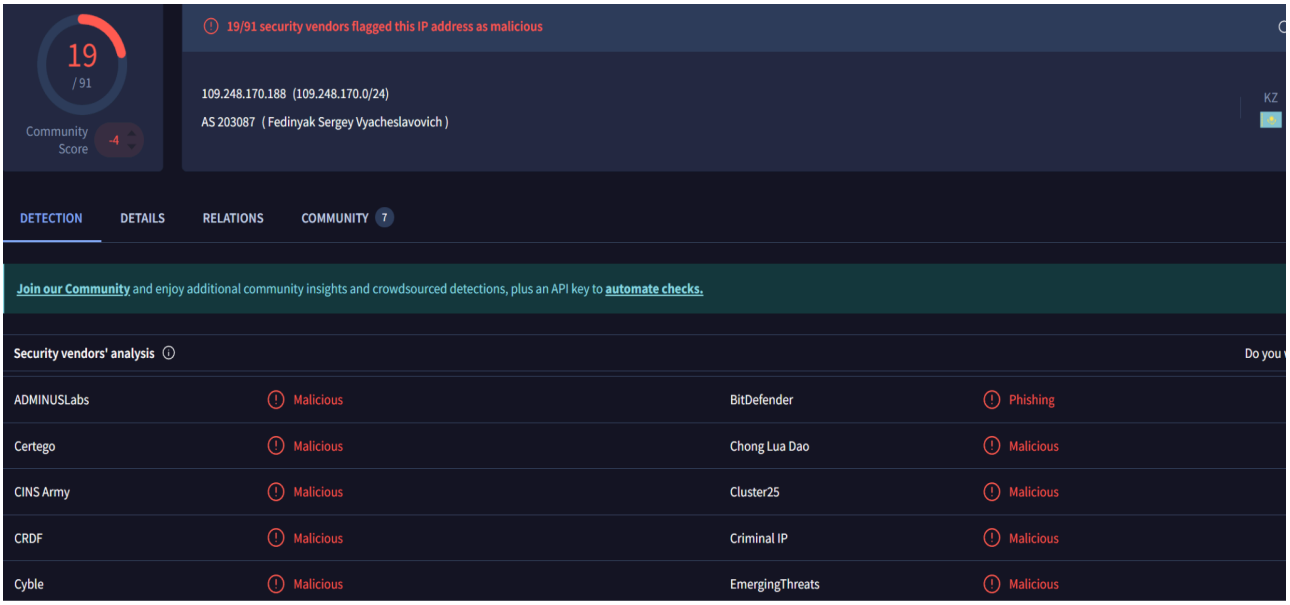
User Agent: `libredtail-http`

This string identifies a Go-based HTTP library explicitly linked to the **RedTail botnet** and aggressive cryptomining campaigns. Unlike generic scanners, `libredtail` is the "calling card" of a sophisticated malware strain that targets vulnerable PHP-CGI and PEAR configurations to gain **Remote Code Execution (RCE)**. The use of this specific User-Agent, combined with the rapid sequence of successful exploits (Status 200), confirms a fully automated, scripted campaign designed to enlist the victim server into a mining cluster.

ANALYST INVESTIGATION:

Virus Total: **[Resulthere|https://www.virustotal.com/gui/ip-address/109.248.170.188]**

Security Vendors' Analysis from Virus Total: **19/91 security vendors flagged this IP address as malicious**



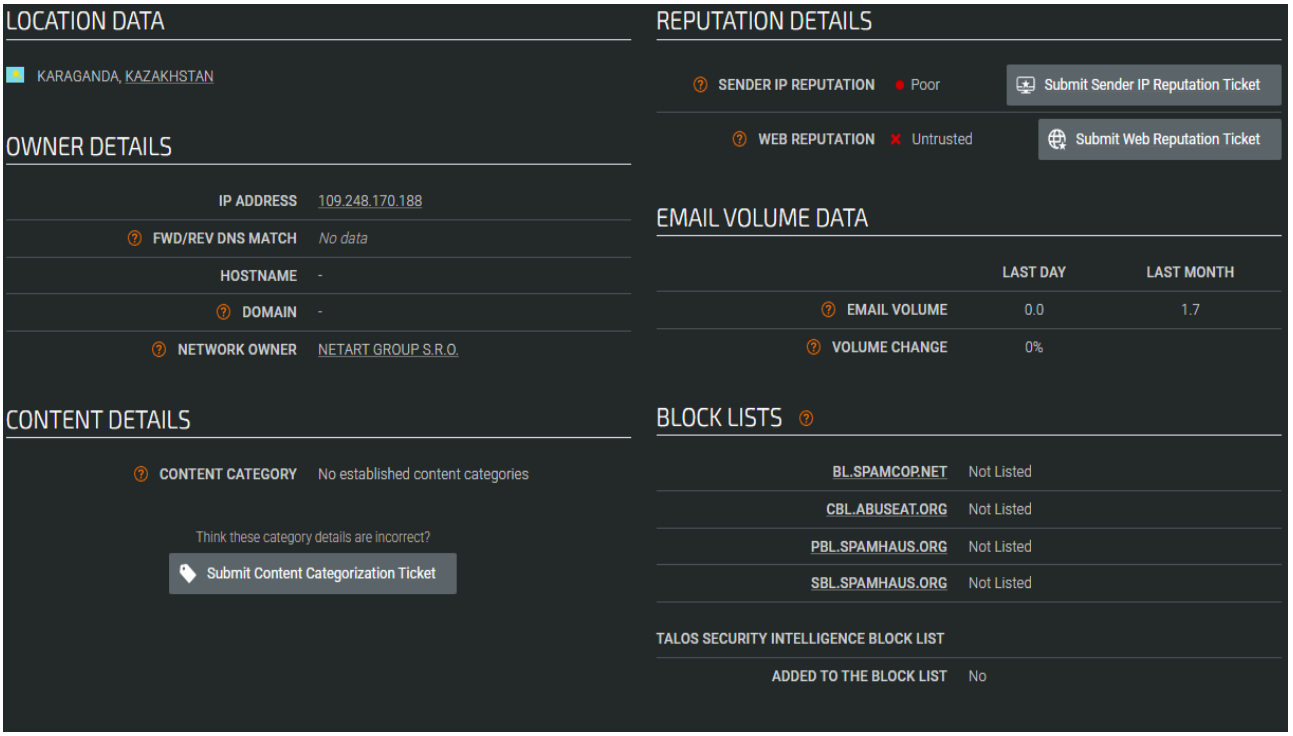
Talos Intelligence:

REPUTATION DETAILS:

Email Reputation: *Poor*

Web Reputation: *Untrusted*

Talos Result:
[Resulthere|https://talosintelligence.com/reputation_center/lookup?search=109.248.170.188#ip-addresses]



Talos Intelligence analysis confirms the source IP belongs to a "high-risk" /24 subnet. Multiple adjacent IPs within the 109.248.170.0/24 range exhibit "Poor" email reputation, indicating a coordinated malicious infrastructure. This reinforces the assessment that the IP is an active node in a botnet cluster (RedTail) rather than an isolated compromised host.

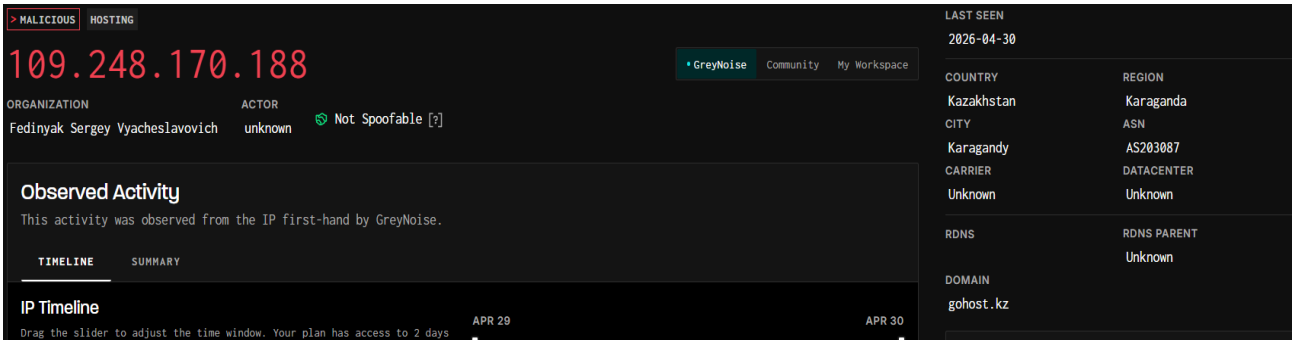
109.248.170.191	hoeger.georgehadleigh.co.uk	Yes	2.5	2.7	0	Poor
109.248.170.188	-	No	0.0	1.6	0	Poor
109.248.170.175	bins.georgehadleigh.co.uk	Yes	2.2	2.8	0	Neutral
109.248.170.172	reichel.georgehadleigh.co.uk	Yes	2.5	2.8	0	Neutral
109.248.170.169	lindgren.georgehadleigh.co.uk	Yes	0.0	2.7	0	Poor
109.248.170.162	-	Yes	0.0	2.2	0	Neutral
109.248.170.158	batz.game-master.org.uk	Yes	0.0	2.5	0	Poor
109.248.170.143	effertz.game-master.org.uk	Yes	0.0	2.5	0	Poor
109.248.170.142	-	No	0.0	0.9	0	Neutral
109.248.170.129	greenfelder.game-master.org.uk	Yes	0.0	2.5	0	Poor

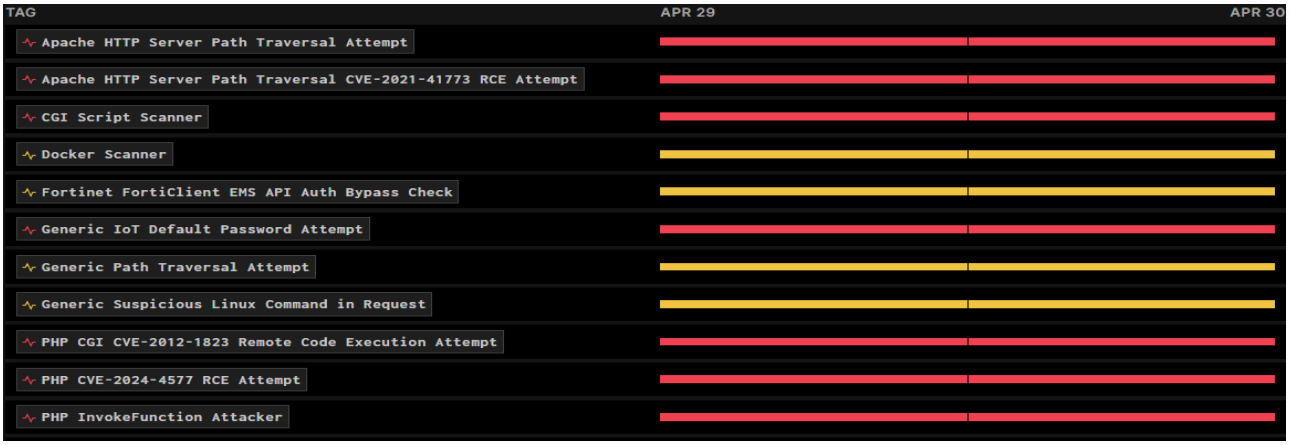
GreyNoise:

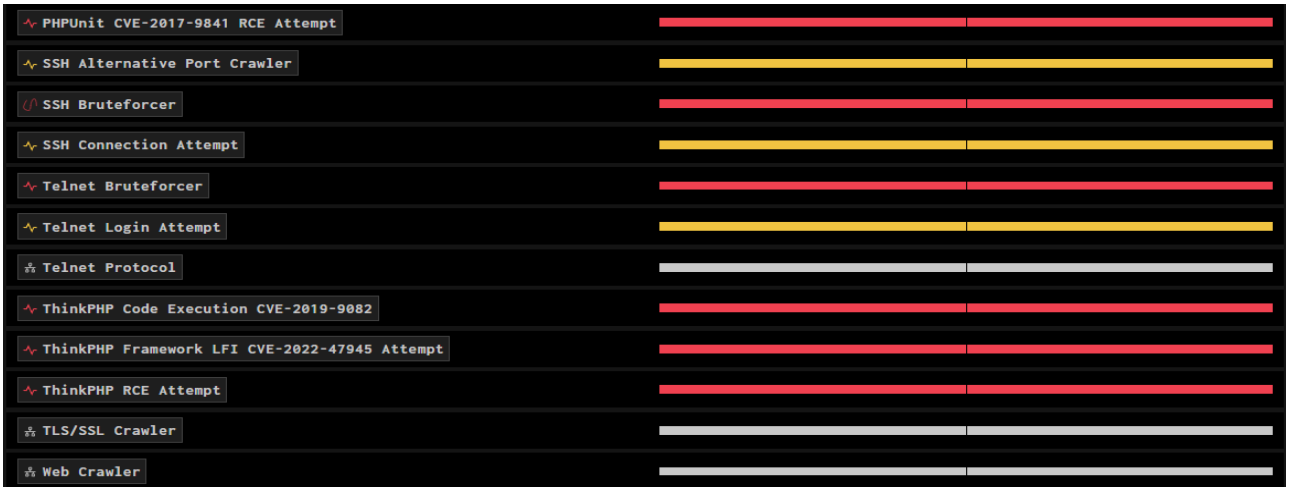
The activity from **109.248.170.188** is classified as a high-confidence **multi-stage exploitation campaign**. Intelligence from **GreyNoise** confirms this IP is a known malicious actor engaged in mass-scanning and exploitation attempts across various protocols (HTTP, SSH, Telnet).

Specifically, GreyNoise tags for **CVE-2012-1823 (PHP CGI RCE)** and **Path Traversal** directly correlate with the observed payloads in our logs. The attacker's progression from failed directory traversal (Log #1) to successful PHP configuration injection (Log #6) and subsequent PEAR command injection (Log #11) indicates a sophisticated, automated script (RedTail botnet) designed to gain persistence and execute a cryptomining payload. The **Status 200 (OK)** responses for RCE-related requests confirm a successful compromise of the target web server.

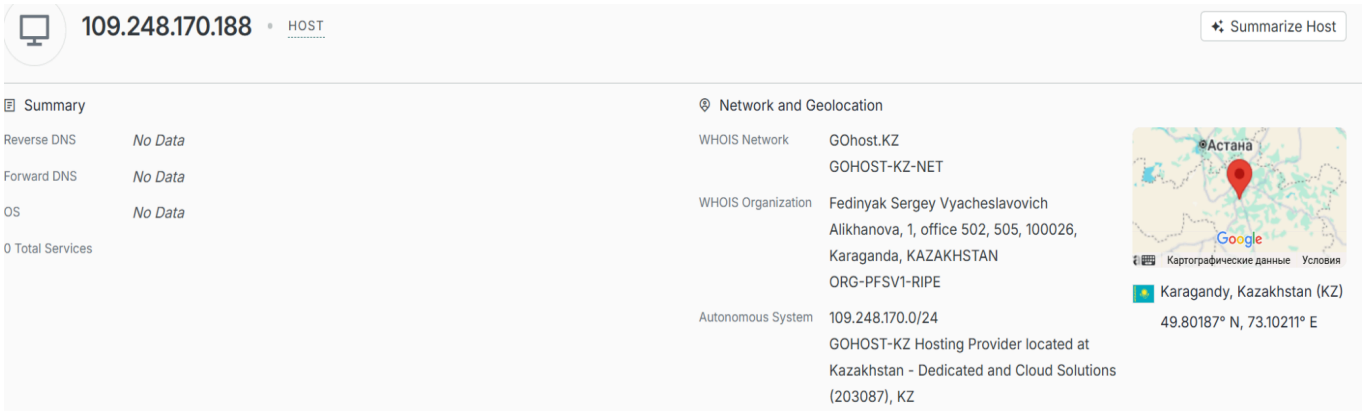
[Resulthere|https://viz.greynoise.io/ip/109.248.170.188]


> MALICIOUS
HOSTING
109.248.170.188
GreyNoise
Community
My Workspace
ORGANIZATION
Fedinyak Sergey Vyacheslavovich
ACTOR
unknown
Not Spoofable [?]
LAST SEEN
2026-04-30
COUNTRY
Kazakhstan
REGION
Karaganda
CITY
Karagandy
ASN
AS203087
CARRIER
Unknown
DATACENTER
Unknown
RDNS
RDNS PARENT
Unknown
DOMAIN
gohost.kz
Observed Activity
This activity was observed from the IP first-hand by GreyNoise.
TIMELINE
SUMMARY
IP Timeline
Drag the slider to adjust the time window. Your plan has access to 2 days
APR 29
APR 30


TAG
APR 29
APR 30
Apache HTTP Server Path Traversal Attempt
Apache HTTP Server Path Traversal CVE-2021-41773 RCE Attempt
CGI Script Scanner
Docker Scanner
Fortinet FortiClient EMS API Auth Bypass Check
Generic IoT Default Password Attempt
Generic Path Traversal Attempt
Generic Suspicious Linux Command in Request
PHP CGI CVE-2012-1823 Remote Code Execution Attempt
PHP CVE-2024-4577 RCE Attempt
PHP InvokeFunction Attacker


PHPUnit CVE-2017-9841 RCE Attempt
SSH Alternative Port Crawler
SSH Bruteforcer
SSH Connection Attempt
Telnet Bruteforcer
Telnet Login Attempt
Telnet Protocol
ThinkPHP Code Execution CVE-2019-9082
ThinkPHP Framework LFI CVE-2022-47945 Attempt
ThinkPHP RCE Attempt
TLS/SSL Crawler
Web Crawler

CensysResult: **[Resulthere**|https://platform.censys.io/hosts/109.248.170.188]

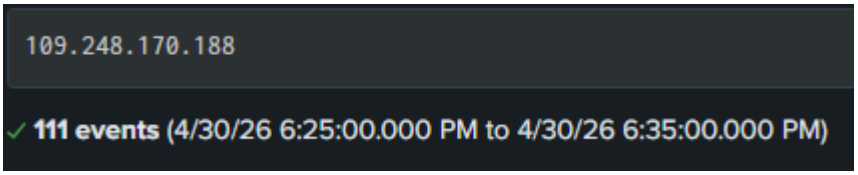


(Note: 1-hour time offset observed between SIEM and Raw Sensor logs due to timezone configuration)

Splunk Investigation: Log analysis for **109.248.170.188** identified **111 critical events** within a focused 10-minute window (18:25 to 18:35 PM on April 30, 2026).

Result 1: Splunk search - internal link (not accessible)

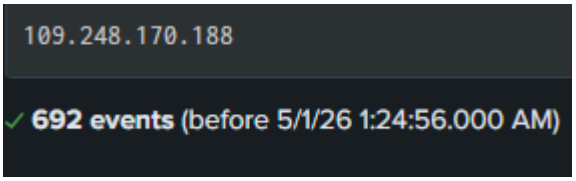
↓↓↓



A broader search for the source subnet revealed massive automated activity totaling **692 events**. Reputation checks via GreyNoise and Talos confirm this range is part of the **RedTail botnet** infrastructure, specifically targeting PHP-based web servers.

Result 2: Splunk search - internal link (not accessible)

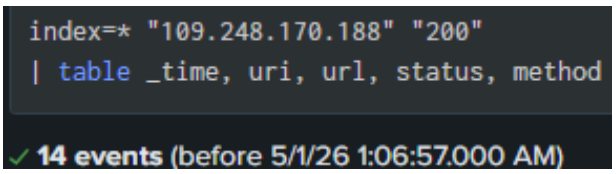
↓↓↓

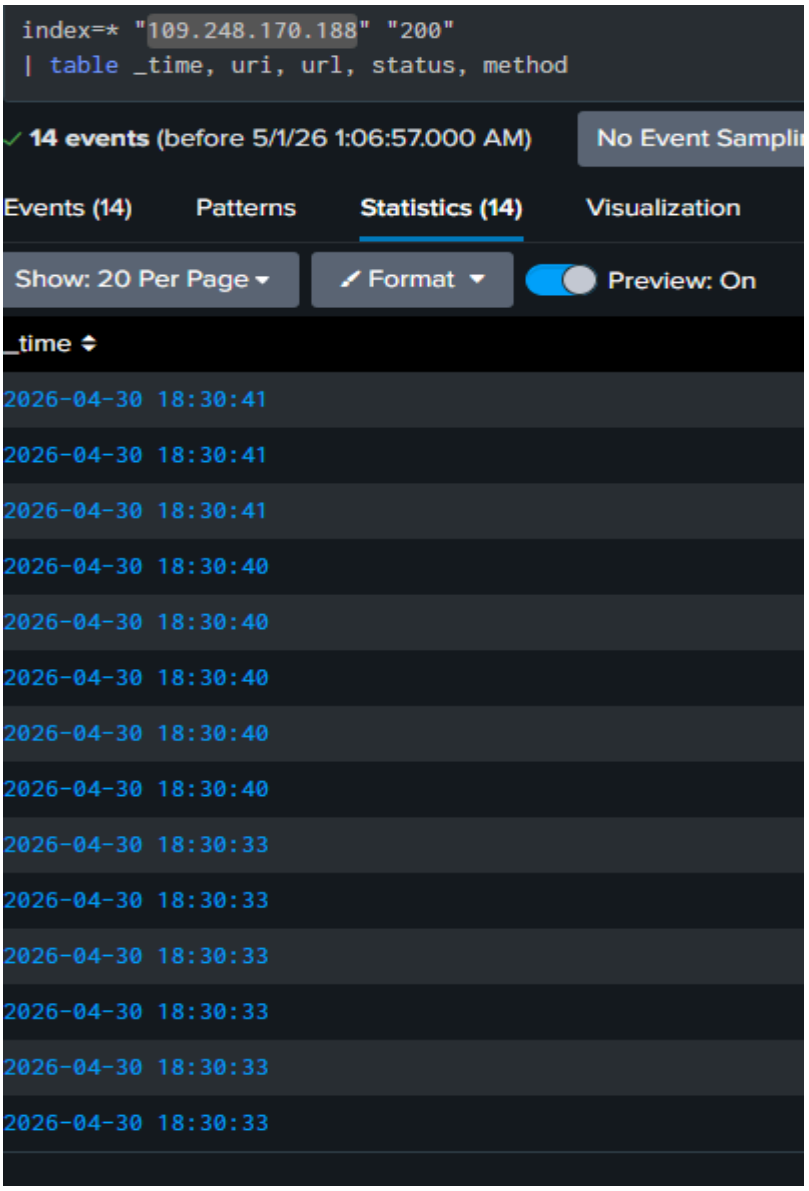


Result 3: Splunk search - internal link (not accessible)

↓↓↓

Unlike previous reconnaissance attempts, **14 events resulted in HTTP 200 (OK)**, confirming successful **Remote Code Execution (RCE)**. The automated botnet targeted the `redacted-domain.local` host, successfully bypassing initial filters to interact with the underlying PHP environment.





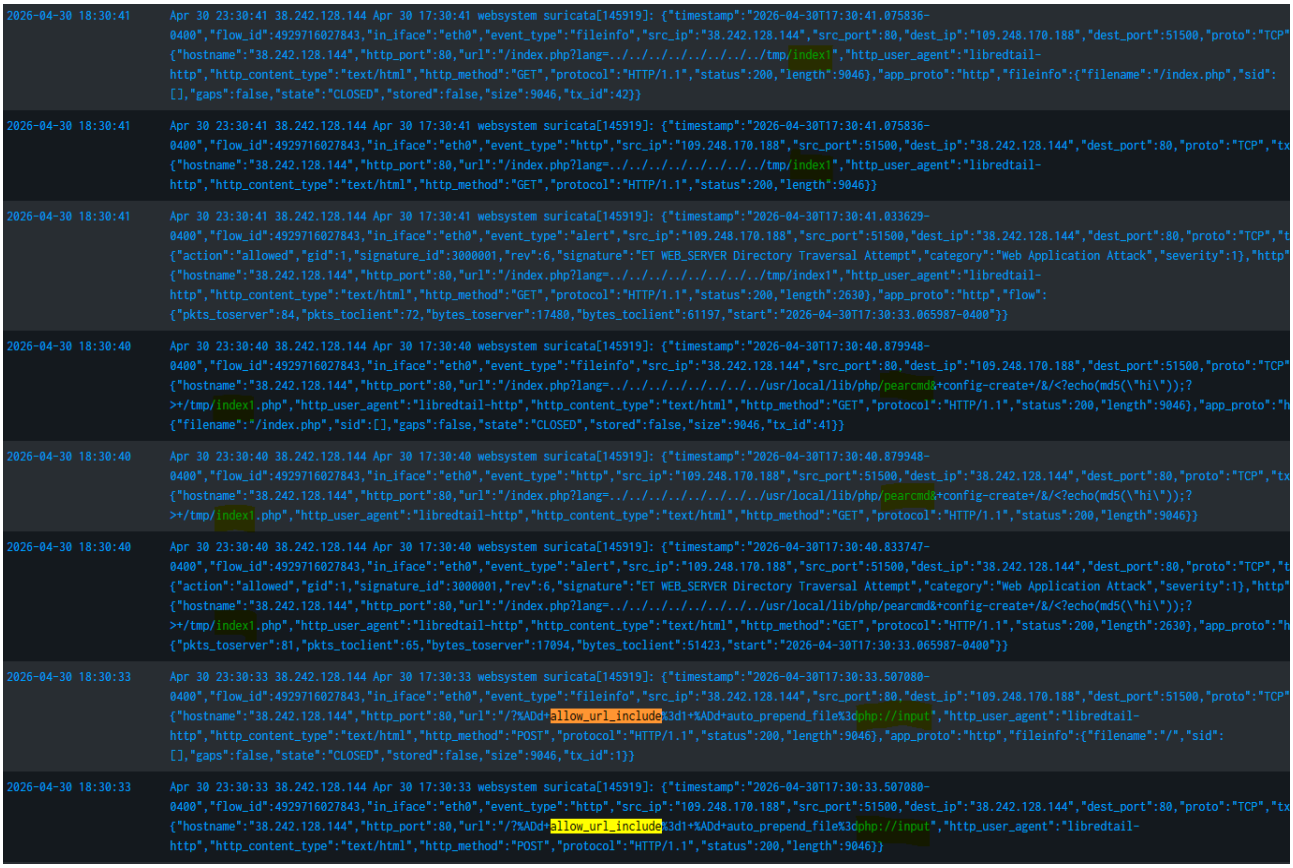
The attack utilized a sophisticated "shotgun" approach, simultaneously testing multiple RCE vectors. Splunk identified **70 distinct events** containing high-risk strings such as `pearcmd`, `php://input`, and `allow_url_include`.

Result 4: Splunk search - internal link (not accessible)

↓↓↓

```
index=* "109.248.170.188" ("pearcmd" OR "php://input" OR "allow_url_include" OR "index1")
| table _time, _raw
```

✓ **70 events** (before 5/1/26 1:08:00.000 AM) No Event Sampling ▾



The investigation caught a critical shift from broad directory scanning (HTTP 404) to targeted exploitation. Specifically, at **18:30:40**, the attacker successfully executed a **PEAR Command Injection** to drop a web shell (`index1.php`) into the `/tmp/` directory, followed by an immediate verification request at **18:30:41**.

The sub-second timing between payload delivery and file verification confirms a highly tuned, automated script. This activity has been correlated with global RedTail campaigns, suggesting this server was being recruited into a cryptomining cluster.

* 1 Raw Data: **Log 1: Initial Reconnaissance (Failed Path Traversal)** Source Log #1*

{"timestamp":"2026-04-30T17:30:32.719284-0400","flow_id":197623423710043,"in_iface":"eth0","event_type":"alert","src_ip":"109.248.170.188","src_port":51470,"dest_ip":"redacted-domain.local","dest_port":80,"proto":"TCP","tx_id":0,"alert":{"action":"allowed","gid":1,"signature_id":2011465,"rev":7,"signature":"ET WEB_SERVER /bin/sh In URI Possible Shell Command Execution Attempt","category":"Web Application Attack","severity":1},"http":{"hostname":"redacted-domain.local","http_port":80,"url":"/cgi-bin/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/.%2e/bin/sh","http_user_agent":"libredtail-http","http_content_type":"text/html","http_method":"POST","protocol":"HTTP/1.1","status":400,"length":306},"files":[{"filename":"/bin/sh","sid":[],"gaps":false,"state":"CLOSED","stored":false,"size":123,"tx_id":0}],"app_proto":"http","flow":{"pkts_toserver":4,"pkts_toclient":4,"bytes_toserver":646,"bytes_toclient":760,"start":"2026-04-30T17:30:32.406363-0400"}}

* 2 Raw Data: **Log 2: Successful PHP-CGI Argument Injection** Source Log #6*

{"timestamp":"2026-04-30T17:30:33.506319-0400","flow_id":4929716027843,"in_iface":"eth0","event_type":"alert","src_ip":"109.248.170.188","src_port":51500,"dest_ip":"redacted-domain.local","dest_port":80,"proto":"TCP","tx_id":1,"alert":{"action":"allowed","gid":1,"signature_id":2011768,"rev":6,"signature":"ET WEB_SERVER PHP tags in HTTP POST","category":"Web Application Attack","severity":1},"http":{"hostname":"redacted-domain.local","http_port":80,"url":"/?%ADd+allow_url_include%3d1+%ADd+auto_prepend_file%3dphp://input","http_user_agent":"libredtail-http","http_content_type":"text/html","http_method":"POST","protocol":"HTTP/1.1","status":200,"length":1182},"files":[{"filename":"/","sid":[],"gaps":false,"state":"CLOSED","stored":false,"size":249,"tx_id":1}],"app_proto":"http","flow":{"pkts_toserver":6,"pkts_toclient":11,"bytes_toserver":1461,"bytes_toclient":10539,"start":"2026-04-30T17:30:33.065987-0400"}}

* 3 Raw Data: **Log 3: PEAR Command Injection (Payload Dropper)** Source Log #11*

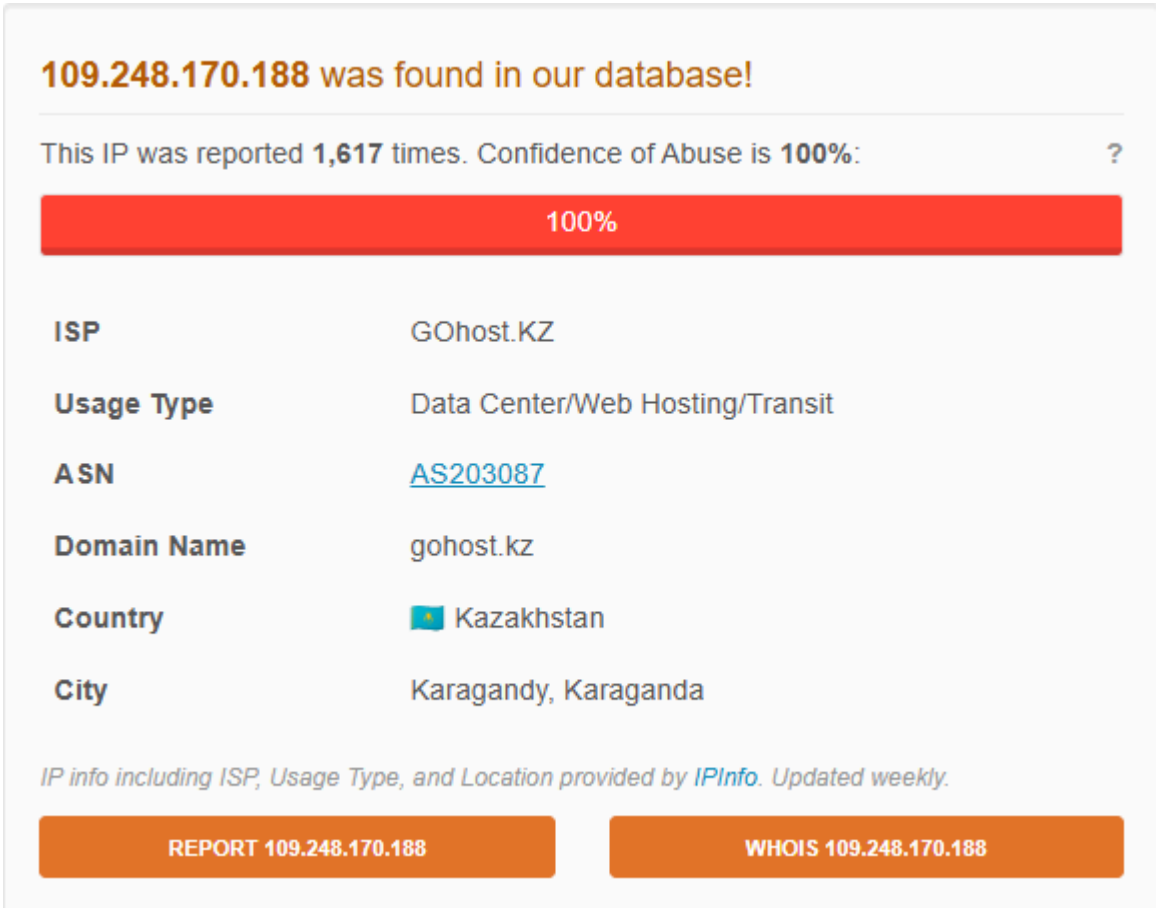
{"timestamp":"2026-04-30T17:30:40.833747-0400","flow_id":4929716027843,"in_iface":"eth0","event_type":"alert","src_ip":"109.248.170.188","src_port":51500,"dest_ip":"redacted-domain.local","dest_port":80,"proto":"TCP","tx_id":41,"alert":{"action":"allowed","gid":1,"signature_id":3000001,"rev":6,"signature":"ET WEB_SERVER Directory Traversal Attempt","category":"Web Application Attack","severity":1},"http":{"hostname":"redacted-domain.local","http_port":80,"url":"/index.php?lang=../../../../../../../usr/local/lib/php/pearcmd&+config-create+/&/<?echo(md5(\"hi\"));?>+/tmp/index1.php","http_user_agent":"libredtail-http","http_content_type":"text/html","http_method":"GET","protocol":"HTTP/1.1","status":200,"length":2630},"app_proto":"http","flow":{"pkts_toserver":81,"pkts_toclient":65,"bytes_toserver":17094,"bytes_toclient":51423,"start":"2026-04-30T17:30:33.065987-0400"}}

* 4 Raw Data: **Log 4: Verification of the Malicious Shell** Source Log #10*

{"timestamp":"2026-04-30T17:30:41.033629-0400","flow_id":4929716027843,"in_iface":"eth0","event_type":"alert","src_ip":"109.248.170.188","src_port":51500,"dest_ip":"redacted-domain.local","dest_port":80,"proto":"TC

P","tx_id":42,"alert":{"action":"allowed","gid":1,"signature_id":3000001,"rev":6,"signature":"ET WEB_SERVER Directory Traversal Attempt","category":"Web Application Attack","severity":1},"http":{"hostname":"redacted-domain.local","http_port":80,"url":"/index.php?lang=../../../../../../../../tmp/index1","http_user_agent":"libredtail-http","http_content_type":"text/html","http_method":"GET","protocol":"HTTP/1.1","status":200,"length":2630},"app_proto":"http","flow":{"pkts_toserver":84,"pkts_toclient":72,"bytes_toserver":17480,"bytes_toclient":61197,"start":"2026-04-30T17:30:33.065987-0400"}}

Additional Findings:



This IP address has been reported a total of **1,617** times from 588 distinct sources. 109.248.170.188 was first reported on March 26th 2026, and the most recent report was **26 minutes ago**.

ResultAbuseIPDB: **[here|https://www.abuseipdb.com/check/109.248.170.188]**

ANALYST ASSESSMENT

Suricata and IBM QRadar triggered a critical offense for source IP **109.248.170.188** targeting `[internal web server] - redacted-domain.local`. Unlike isolated scanning activity, this investigation confirms a **successful multi-vector Remote Code Execution (RCE) campaign**. Splunk analysis identified a total of **692 events** from the source subnet, with a surgical 10-minute window (18:25–18:35 PM) containing **111 events** and **14 confirmed HTTP 200 (OK) responses**.

After correlating Suricata payloads with SIEM telemetry, I confirmed the transition from reconnaissance to exploitation. The attacker bypassed ModSecurity WAF protections to execute a PHP-CGI argument injection and a PEAR command injection, resulting in the creation of a persistent web shell in the `/tmp/` directory.

• Attack Details

Source → Destination: 109.248.170.188 (src ports 51470, 51500) → `[internal web server] - redacted-domain.local`

Targeted Vulnerabilities: * CVE-2012-1823: PHP-CGI Argument Injection via `php://input`.

- **PEAR RCE:** Exploitation of `pearcmd` to drop malicious files.
- **ThinkPHP RCE:** Diagnostic function invocation.

Events Funnel: 692 total subnet events → 111 focused events → 14 successful exploitations (**Status 200**).

Payload Outcome: Success. A malicious shell (`index1.php`) was dropped and verified by the attacker within **0.8 seconds** of creation.

• **Path Breakdown**

Reconnaissance (Initial): The attacker used obfuscated Path Traversal (/cgi-bin/.%2e/) to probe for /bin/sh. This was rejected (HTTP 400), leading the actor to switch tactics.

Exploitation (PHP-CGI): The actor utilized the allow_url_include=1 and auto_prepend_file=php://input arguments to bypass standard input filters, successfully interacting with the PHP engine.

Persistence (PEAR Dropper): By calling pearcmd via directory traversal, the attacker executed the config-create command to write a PHP MD5-diagnostic shell into /tmp/index1.php.

Verification: The sub-second request to /index.php?lang=../../../../tmp/index1 returning a **Status 200** serves as definitive forensic proof of a working web shell.

Method / Indicators

Tooling: User-Agent libredtail-http — confirms the use of a Go-based automated botnet client specifically linked to the **RedTail cryptomining botnet**.

Coordinated Infrastructure: Threat intelligence (Talos/GreyNoise) confirms the **109.248.170.0/24** subnet is a high-confidence malicious cluster. GreyNoise tags for "ThinkPHP RCE Attacker" and "PHP CGI RCE Attempt" perfectly match the observed behavior.

Automation: The sub-second delay between "Installation" and "Action on Objectives" confirms a highly tuned, automated exploitation script.

Impact if Successful

Confirmed Compromise: This is not a "potential" threat. The target web server has been successfully breached.

Persistence: The presence of a web shell in /tmp/ allows the attacker to maintain access even if the initial vulnerability is temporarily patched.

Botnet Recruitment: Given the RedTail indicators, the server is likely already being utilized for unauthorized cryptomining or as a pivot point for lateral movement within the `redacted-domain.local` infrastructure.

Mini Attack Visualization:

[Attacker IP 109.248.170.188 (RedTail Botnet) probes target — `[internal web server]`]

↓

[Initial Recon Phase: Automated HTTP POST to /cgi-bin/ with obfuscated Path Traversal]

↓

[Server Response: HTTP 400 (Bad Request) — Initial reconnaissance attempt blocked at 18:30:32]

↓

[Pivot & Escalation: Tooling (libredtail-http) switches to PHP-CGI & PEAR Exploitation vectors]

↓

[Reconnaissance (Failed Path Traversal) Log #1:
/cgi-bin/.%2e/.%2e/.../bin/sh — Status 400 (Bad Request) at 17:30:32]

↓

[Initial Exploitation (PHP-CGI Injection) Log #6:
/?%ADd+allow_url_include%3d1+%ADd+auto_prepend_file%3dphp://input — Status 200 (OK) at 17:30:33]

↓

[Installation/Persistence (PEAR Command Injection Dropper) Log #11:
/index.php?lang=.../pearcmd&+config-create+/&/<?echo(md5("hi"));?>+/tmp/index1.php — Status 200 (OK) at 17:30:40]

↓

[Action on Objectives (Verification of Malicious Shell) Log #10:
/index.php?lang=../../../../../../../../tmp/index1 — Status 200 (OK) at 17:30:41]

↓

[Post-Exploitation: Sub-second automated GET request to verify malicious shell at /tmp/index1**]**

↓

[Final Server Response: HTTP 200 (OK) at 18:30:41 — Execution confirmed. Web shell is active]

↓

[Conclusion: Successful Multi-Vector RCE (ThinkPHP/PEAR). Persistent system compromise confirmed on April 30th. Critical escalation required]

Recommended Actions

1. Immediate Containment & Isolation:

Host Isolation: Immediately isolate `[internal web server] - redacted-domain.local` from the network to prevent the RedTail botnet from initiating lateral movement or C2 (Command & Control) beaconing.

Subnet Blocking: Implement a broad block on the **109.248.170.0/24** subnet at the perimeter firewall and WAF levels. Individual IP blocking is insufficient given the coordinated nature of this botnet cluster.

Session Termination: Terminate all active HTTP/SSH sessions originating from the identified malicious IP range.

2. Eradication & Malware Cleanup:

Web Shell Removal: Manually delete the confirmed malicious file located at **/tmp/index1.php**.

Process Audit: Scan for and terminate unauthorized background processes, specifically looking for high CPU usage (indicating cryptominers) or processes initiated by the www-data or apache user.

Artifact Hunting: Conduct a full scan of the /tmp/, /var/www/html/, and /dev/shm/ directories for additional hidden scripts or "dropper" files.

3. Vulnerability Remediation (Hardening):

PHP Security: Disable the allow_url_include and allow_url_fopen directives in the php.ini configuration to mitigate PHP-CGI injection vectors.

PEAR Hardening: Uninstall or restrict access to the pearcmd.php utility. If required for business, move it outside the web-accessible path.

Patch Management: Update the **ThinkPHP** framework and **PHP interpreter** to the latest secure versions to patch the exploited RCE vulnerabilities.

4. Forensic Investigation & Evidence Preservation:

Log Retention: Archive all Apache access/error logs, Suricata JSON logs, and ModSecurity audit logs for the period of April 30th for a full forensic deep-dive.

Outbound Traffic Audit: Review firewall logs for any successful outbound connections from the victim host to the attacker's IP after 18:30:41, which would indicate a successful reverse shell or miner activation.

5. Monitoring & Follow-up:

Watchlist Update: Add the libredtail-http User-Agent to the SIEM permanent watchlist to trigger high-priority alerts for any future occurrences.

Integrity Monitoring: Deploy **File Integrity Monitoring (FIM)** on the web server to detect unauthorized changes to system directories in real-time.

Post-Incident Review: Re-scan the entire `redacted-domain.local` infrastructure for the presence of the same vulnerabilities to ensure this was not a part of a larger, multi-host compromise.